

GS+ + control deltas github 02.04.26 & 20.04.26

Inhalte

- Entfernte Anforderungen
- Neue Anforderungen
- Veränderte Anforderungsattribute

Entfernte Anforderungen

[Zurück zu Inhalte](#)

Anzahl entfernter Anforderungen: 0

Neue Anforderungen

[Zurück zu Inhalte](#)

Anzahl neuer Anforderungen: 0

Veraenderte Anforderungsattribute

[Zurück zu Inhalt](#)

Anzahl geänderter Anforderungsattribute: 12

Anforderung	Geänderte Attribute
GC.5.1.2	Hinweis
KONF.7.3	Modalverb, Text
NOT.2.1	Hinweis, Titel
NOT.2.1.4	Verwandte
NOT.3.1	Hinweis
NOT.3.4	Hinweis, Verwandte
NOT.4.1	Hinweis
NOT.4.6	Hinweis
NOT.4.14	Hinweis

GC.5.1.2 Festlegung des Schutzbedarfs (normal-SdT)

Attribut	02.04.26	20.04.26
Hinweis	Das Ergebnis der Schutzbedarfsfeststellung ist eine Übersicht des Schutzbedarfs der zu verarbeitenden Informationen, sowie der Relevanz der Geschäftsprozesse. Die	Das Ergebnis der Schutzbedarfsfeststellung ist eine Übersicht des Schutzbedarfs der zu verarbeitenden Informationen, sowie der Relevanz der Geschäftsprozesse. Die

Attribut	02.04.26	20.04.26
	Einstufung erfolgt dabei in den Stufen „normal“ oder „hoch“. Die Einstufung richtet sich nach der Bedeutung des Geschäftsprozess für die Geschäftsziele oder den gesetzlichen Auftrag der Institution. Priorität für die weitere Abarbeitung hat zunächst der wichtigste Geschäftsprozess, d. h. derjenige Geschäftsprozess, dessen Informationsschutz für den Fortbestand der Institution von essentieller Bedeutung ist. Die Entscheidung darüber, welcher Geschäftsprozess am wichtigsten ist, obliegt der Institutionsleitung. Droht bei einer Verletzung der Vertraulichkeit, Integrität oder Verfügbarkeit von Informationen in diesem Geschäftsprozess ein existenzbedrohender finanzieller oder existenzbedrohender Reputationsschaden, so ist der Schutzbedarf des Prozesses als hoch einzustufen. Das gleiche gilt, wenn [- ein Geschäftsprozess oder eine Information -], als [- (VS -) -] Vertraulich eingestuft [- wird -].	Einstufung erfolgt dabei in den Stufen „normal“ oder „hoch“. Die Einstufung richtet sich nach der Bedeutung des Geschäftsprozess für die Geschäftsziele oder den gesetzlichen Auftrag der Institution. Priorität für die weitere Abarbeitung hat zunächst der wichtigste Geschäftsprozess, d. h. derjenige Geschäftsprozess, dessen Informationsschutz für den Fortbestand der Institution von essentieller Bedeutung ist. Die Entscheidung darüber, welcher Geschäftsprozess am wichtigsten ist, obliegt der Institutionsleitung. Droht bei einer Verletzung der Vertraulichkeit, Integrität oder Verfügbarkeit von Informationen in diesem Geschäftsprozess ein existenzbedrohender finanzieller oder existenzbedrohender Reputationsschaden, so ist der Schutzbedarf des Prozesses als hoch einzustufen. Das gleiche gilt, wenn [+ innerhalb eines Geschäftsprozesses Informationen verarbeitet werden +], [+ die +] als [+ besonders +] vertraulich eingestuft [+ werden +].

KONF.7.3 Host-basierte Angriffserkennung (erhöht)

Attribut	02.04.26	20.04.26
Modalverb	SOLLTE	KANN
Text	Konfiguration für IT-Systeme SOLLTE Host-basierte Angriffserkennung aktivieren.	Konfiguration für IT-Systeme KANN Host-basierte Angriffserkennung aktivieren.

NOT.2.1 Verfahren und Regelungen zur BAO (normal-SdT)

Attribut	02.04.26	20.04.26
Hinweis	Eine BAO ermöglicht, in Notfällen und Krisen schnellstmöglich auf das Schadensereignis zu reagieren. Eine BAO gehört zu den originären Aufgaben eines BCMS [- und SOLL von diesem etabliert werden -]. Wird bzw. wurde ein BCMS nach BSI- Standard 200- 4 aufgebaut (unabhängig von der Stufe), so sind die BAO-betreffenden Anforderungen in der Regel	Eine BAO ermöglicht, in Notfällen und Krisen schnellstmöglich auf das Schadensereignis zu reagieren. Eine BAO gehört zu den originären Aufgaben eines BCMS. Wird bzw. wurde ein BCMS nach BSI- Standard 200- 4 aufgebaut (unabhängig von der Stufe), so sind die BAO-betreffenden Anforderungen in der Regel erfüllt und werden im Rahmen

Attribut	02.04.26	20.04.26
	erfüllt und werden im Rahmen des BCMS anhand des BSI- Standards 200- 4 detaillierter definiert. Nähere Informationen können dem BSI- Standard 200- 4 in Kapitel 5 Aufbau und Befähigung der BAO (R+ AS) entnommen werden. Die einzelnen Regelungen können den untergliederten Anforderungen entnommen werden.	des BCMS anhand des BSI- Standards 200- 4 detaillierter definiert. Nähere Informationen können dem BSI- Standard 200- 4 in Kapitel 5 Aufbau und Befähigung der BAO (R+ AS) entnommen werden. Die einzelnen Regelungen können den untergliederten Anforderungen entnommen werden.
Titel	Verfahren und Regelungen	Verfahren und Regelungen zur BAO

NOT.2.1.4 Stabsübung (erhöht)

Attribut	02.04.26	20.04.26
Verwandte		#NOT.3.4

NOT.3.1 Wiederanlaufplan (normal-SdT)

Attribut	02.04.26	20.04.26
Hinweis	Ein Wiederanlaufplan legt fest, wie eine ausgefallene (IT)- Ressource auf ein vorgesehenes Notbetriebsniveau innerhalb einer Wiederanlaufzeit durch Notfallteams zur Verfügung gestellt wird. Besteht ein BCMS, dann werden die [- zeitkritischen -] Ressourcen innerhalb der Business Impact Analyse identifiziert und in dieser entsprechende Wiederanlaufzeiten festgelegt. Die ausgewählten BC- Strategien des BCMS bieten ferner den Rahmen für die Wiederanlaufplanung. Besteht kein BCMS, dann können die zeitkritischen IT- Ressourcen anhand der Schutzbedarfsfeststellung (erhöhter Schutzbedarf in der Verfügbarkeit) identifiziert werden. Die Wiederanlaufzeit kann dann nur grob anhand der Ergebnisse der [- Schutzbedarfsfeststellung -] geschätzt werden. Nähere Informationen können dem BSI- Standard 200- 4 Kapitel 12 Wiederanlauf- und	Ein Wiederanlaufplan legt fest, wie eine ausgefallene (IT)- Ressource auf ein vorgesehenes Notbetriebsniveau innerhalb einer Wiederanlaufzeit durch Notfallteams zur Verfügung gestellt wird. Besteht ein BCMS, dann werden die [+ kritischen +] Ressourcen innerhalb der Business Impact Analyse identifiziert und in dieser entsprechende Wiederanlaufzeiten festgelegt. Die ausgewählten BC- Strategien des BCMS bieten ferner den Rahmen für die Wiederanlaufplanung. Besteht kein BCMS, dann können die zeitkritischen IT- Ressourcen anhand der Schutzbedarfsfeststellung (erhöhter Schutzbedarf in der Verfügbarkeit) identifiziert werden. Die Wiederanlaufzeit kann dann nur grob anhand der Ergebnisse der [+ Informationssicherheitseinstufung +] geschätzt werden [+ . Zeitkritisch sind IT - Systeme und Anwendungen genau dann , wenn ihre fortlaufende Verfügbarkeit für die Aufrechterhaltung des Geschäftsbetriebes auch im Notfall zwingend erforderlich ist +] . Nähere Informationen können dem BSI- Standard 200- 4 Kapitel 12 Wiederanlauf- und Wiederherstellungsplanung (AS) entnommen werden.

Attribut	02.04.26	20.04.26
----------	----------	----------

	Wiederherstellungsplanung (AS) entnommen werden.	
--	---	--

NOT.3.4 Funktionstest (erhöht)

Attribut	02.04.26	20.04.26
----------	----------	----------

Hinweis	Eine regelmäßige Überprüfung hilft zu erkennen, ob die verschiedenen Notfallpläne (z. B. Wiederanlaufplan, Geschäftsfortführungsplan) und Notbetriebsressourcen tatsächlich funktionieren und die Zuständigen die Verfahrensweisen beherrschen. Mit der tatsächlichen Funktionstüchtigkeit ist gemeint, dass nicht nur die Aktualität der Pläne betrachtet wird, sondern soweit möglich auch die konkreten Ressourcen geprüft werden (z. B. laufen die Meldewege wie vorgesehen, lassen sich Ausfallleitungen aktivieren, sind Ersatzgeräte nutzbar). Ist hierzu noch nicht die erforderliche Reife erlangt, können in einem ersten Schritt Planbesprechungen, die nur virtuell einen Plan überprüfen, eingesetzt werden. Nähere Informationen können dem BSI- Standard 200- 4 Kapitel 13. 9 Funktionstest (R optional+ AS) und 13. 5 Planbesprechung (R optional+ AS) entnommen werden.	Eine regelmäßige Überprüfung hilft zu erkennen, ob die verschiedenen Notfallpläne (z. B. Wiederanlaufplan, Geschäftsfortführungsplan) und Notbetriebsressourcen tatsächlich funktionieren und die Zuständigen die Verfahrensweisen beherrschen. Mit der tatsächlichen Funktionstüchtigkeit ist gemeint, dass nicht nur die Aktualität der Pläne [+ theoretisch +] betrachtet wird, sondern soweit möglich auch die konkreten Ressourcen geprüft werden (z. B. laufen die Meldewege wie vorgesehen, lassen sich Ausfallleitungen aktivieren, sind Ersatzgeräte nutzbar). Ist hierzu noch nicht die erforderliche Reife erlangt, können in einem ersten Schritt Planbesprechungen, die nur virtuell einen Plan überprüfen, eingesetzt werden. Nähere Informationen können dem BSI- Standard 200- 4 Kapitel 13. 9 Funktionstest (R optional+ AS) und 13. 5 Planbesprechung (R optional+ AS) entnommen werden.
---------	---	--

Verwandte	#NOT.2.1.4
-----------	------------

NOT.4.1 Dokumentation der Quellen (normal-SdT)

Attribut	02.04.26	20.04.26
----------	----------	----------

Hinweis	Datensicherungen dienen der Wiederherstellung von Daten nach Vorfällen. Aufgrund der besonderen Bedeutung fordert auch die ISO/ IEC 27001 die Sicherung von Informationen in Übereinstimmung mit themenspezifischen Regelungen zur Datensicherung. Hierzu gehört die Regelung, welche Daten konkret gesichert werden (Quellen, [- Datenkategorien -], Umfang).	Datensicherungen dienen der Wiederherstellung von Daten nach Vorfällen. Aufgrund der besonderen Bedeutung fordert auch die ISO/ IEC 27001 die Sicherung von Informationen in Übereinstimmung mit themenspezifischen Regelungen zur Datensicherung. Hierzu gehört die Regelung, welche Daten konkret gesichert werden (Quellen, [+ Kategorien oder Klassifikation
---------	--	--

Attribut	02.04.26	20.04.26
	Relevant sind dabei auch Daten, die bei Dienstleistern oder in der Cloud aufbewahrt werden. Die Datensicherung kann auch durch die Sicherung ganzer IT- Systeme, Datenträger oder Netzlaufwerke umgesetzt werden. Es empfiehlt sich auch zu prüfen, wie die Institution ihre Daten, welche bei einem Outsourcing Dienstleister liegen, sichern will. Es ist möglich eine Datensicherung durch den Dienstleister oder auch bei sich selbst zu erstellen.	der Daten +], Umfang). Relevant sind dabei auch Daten, die bei Dienstleistern oder in der Cloud aufbewahrt werden. Die Datensicherung kann auch durch die Sicherung ganzer IT- Systeme, Datenträger oder Netzlaufwerke umgesetzt werden. Es empfiehlt sich auch zu prüfen, wie die Institution ihre Daten, welche bei einem Outsourcing Dienstleister liegen, sichern will. Es ist möglich eine Datensicherung durch den Dienstleister oder auch bei sich selbst zu erstellen.

NOT.4.6 Geschützte Aufbewahrung (normal-SdT)

Attribut	02.04.26	20.04.26
Hinweis	Eine geschützte Aufbewahrung von Datensicherungen bedeutet, dass Sicherungskopien nicht nur vorhanden sind, sondern auch vor Verlust, Manipulation oder unbefugtem Zugriff bewahrt werden. Dabei wird berücksichtigt, dass Datensicherungen häufig ein attraktives Ziel für Angriffe darstellen und gleichzeitig im Notfall die einzige Möglichkeit zur Wiederherstellung von Systemen und Daten sein können. Beispiele für Schutzmaßnahmen sind die Ablage von Sicherungsmedien in feuer- und wasserfesten Tresoren, die Nutzung getrennter Räumlichkeiten oder externer Rechenzentren mit physischen Sicherheitsvorkehrungen sowie die Verschlüsselung von Backups, wenn diese an externen Standorten oder in Cloud-Umgebungen gespeichert werden. Auch organisatorische Maßnahmen wie eine klare Regelung, wer Zugriff auf die Sicherungen erhält, tragen zum Schutz bei.	Eine geschützte Aufbewahrung von Datensicherungen bedeutet, dass Sicherungskopien nicht nur vorhanden sind, sondern auch vor Verlust, Manipulation [+ , versehentlicher Löschung +] oder unbefugtem Zugriff bewahrt werden. Dabei wird berücksichtigt, dass Datensicherungen häufig ein attraktives Ziel für Angriffe darstellen und gleichzeitig im Notfall die einzige Möglichkeit zur Wiederherstellung von Systemen und Daten sein können. Beispiele für Schutzmaßnahmen sind die Ablage von Sicherungsmedien in feuer- und wasserfesten Tresoren, die Nutzung getrennter Räumlichkeiten oder externer Rechenzentren mit physischen Sicherheitsvorkehrungen sowie die Verschlüsselung von Backups, wenn diese an externen Standorten oder in Cloud-Umgebungen gespeichert werden. Auch organisatorische Maßnahmen wie eine klare Regelung, wer Zugriff auf die Sicherungen erhält, tragen zum Schutz bei.

NOT.4.14 Offline-Kopie (normal-SdT)

Attribut 02.04.26**20.04.26****Hinweis**

Eine Offline- Kopie ist eine Datensicherung, die physisch oder logisch von produktiven Systemen und dem laufenden Netzwerk getrennt ist („ offline backup“ oder „ air-gapped backup“). „ Regelmäßig“ bedeutet, dass die Institution in Abhängigkeit von Verfügbarkeit und Kritikalität ihrer Daten feste Intervalle definiert, beispielsweise täglich, wöchentlich oder monatlich. Der Sinn und Zweck dieser Vorgabe liegt darin, sicherzustellen, dass im Falle von Schadsoftwarebefall oder gezielten Angriffen keine gleichzeitige Kompromittierung aller Sicherungskopien stattfinden kann; ein Angriff könnte sonst auch Backups verschlüsseln oder löschen. Eine Offline- Kopie kann dagegen die Wiederherstellung kritischer Systeme nach einem Ransomware- Angriff oder auch nach einem physischen Ausfall, etwa durch Stromschaden oder Brand, unterstützen. Eine Institution kann dies umsetzen, indem sie (1) **[- Backups -]** auf **[- wechselbare -]** Medien wie **[- externe -]** Festplatten, RDX- Kassetten oder **[- Bänder -]** erstellt, die nach dem Backup- Vorgang vom Netzwerk getrennt und **[- sicher -]** aufbewahrt werden, (2) Cloud- Backups so konfiguriert, dass sie durch Write- Once- Read- Many- (WORM)- Speicher geschützt und logisch von aktiven Systemen isoliert sind, oder (3) eine Rotation von Datenträgern einführt, bei der Kopien an einem separaten, physischen Standort verwahrt werden.

Eine Offline- Kopie ist eine Datensicherung, die physisch oder logisch von produktiven Systemen und dem laufenden Netzwerk getrennt ist („ offline backup“ oder „ air-gapped backup“). „ Regelmäßig“ bedeutet, dass die Institution in Abhängigkeit von Verfügbarkeit und Kritikalität ihrer Daten feste Intervalle definiert, beispielsweise täglich, wöchentlich oder monatlich. Der Sinn und Zweck dieser Vorgabe liegt darin, sicherzustellen, dass im Falle von Schadsoftwarebefall oder gezielten Angriffen keine gleichzeitige Kompromittierung aller Sicherungskopien stattfinden kann; ein Angriff könnte sonst auch Backups verschlüsseln oder löschen. Eine Offline- Kopie kann dagegen die Wiederherstellung kritischer Systeme nach einem Ransomware- Angriff oder auch nach einem physischen Ausfall, etwa durch Stromschaden oder Brand, unterstützen. Eine Institution kann dies umsetzen, indem sie (1) **[+ Kopien in Papierform oder +]** auf **[+ wechselbaren +]** Medien wie **[+ externen +]** Festplatten, RDX- Kassetten oder **[+ Bändern +]** erstellt, die nach dem Backup- Vorgang vom Netzwerk getrennt und **[+ geschützt +]** aufbewahrt werden, (2) Cloud- Backups so konfiguriert, dass sie durch Write- Once- Read- Many- (WORM)- Speicher geschützt und logisch von aktiven Systemen isoliert sind, oder (3) eine Rotation von Datenträgern einführt, bei der Kopien an einem separaten, physischen Standort verwahrt werden.